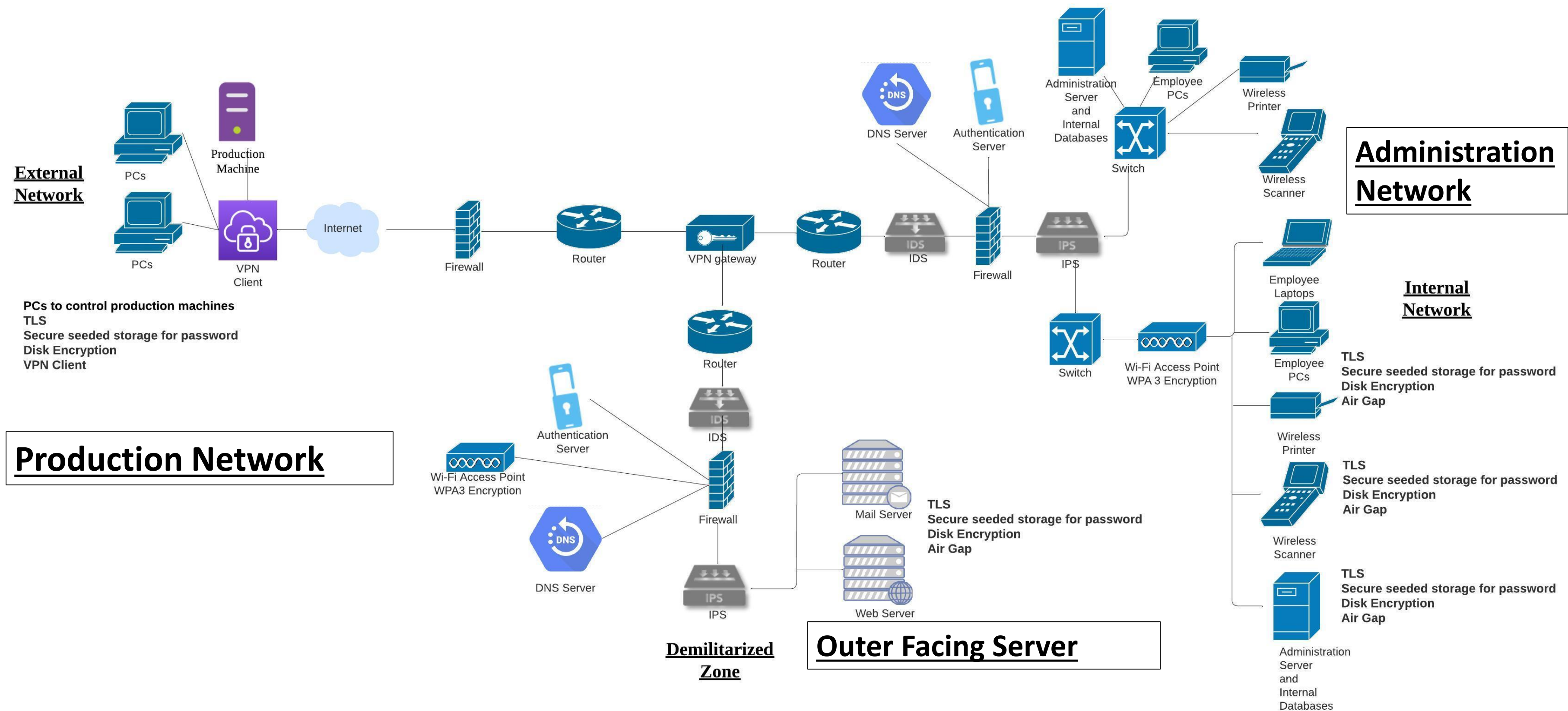




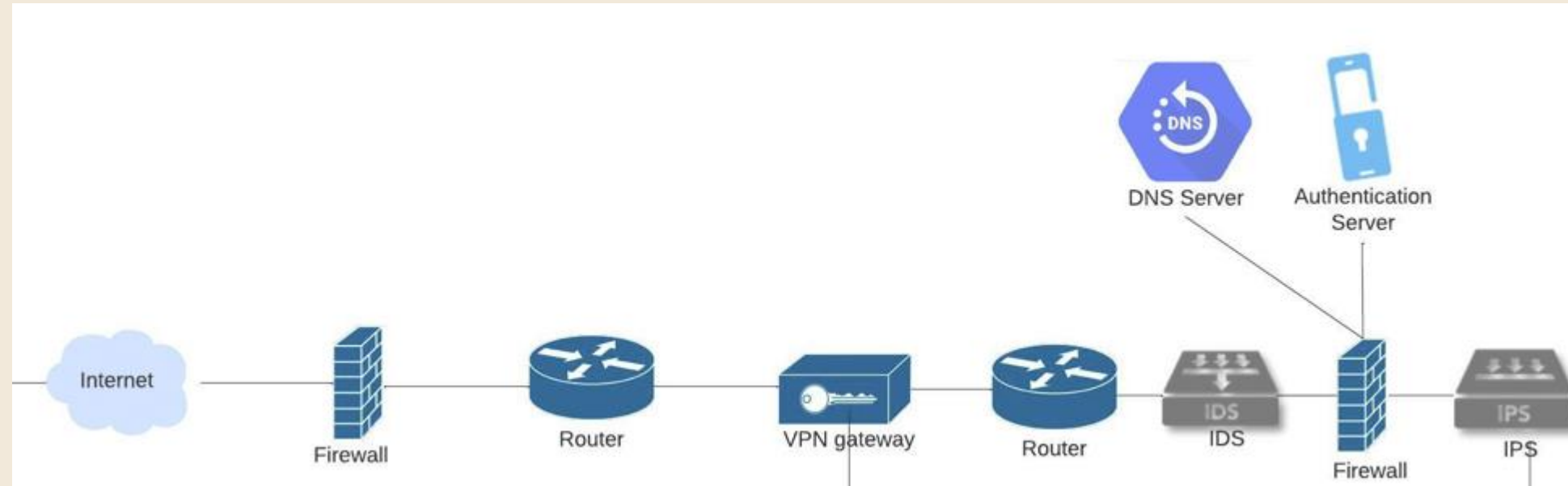
SECURITY CONTROLS IN A MEDIUM-SIZED COMPANY SCENARIO

Ong Ying Tong 34477306

Network Diagram



Before Access to Administration Network



External Firewall

Firewall help to analyze incoming and outgoing packets that come from external networks based on security rules. Port numbers allowed to be accessed: TCP 443, TCP 80, TCP 25, TCP 465, TCP 587, TCP 993, TCP 995, TCP 636, UDP 53, UDP 1194 (Administration server, Web Server, Mail Server, Authentication Server, Mail Client)

Router

The router ensures efficient and secure data flow across the network which forward data packets within network. Port numbers allowed to be accessed: TCP 443, TCP 80, TCP 25, TCP 465, TCP 587, TCP 993, TCP 995, TCP 636, UDP 53, UDP 1194 (Administration server, Web Server, Mail Server, Authentication Server, Mail Client)

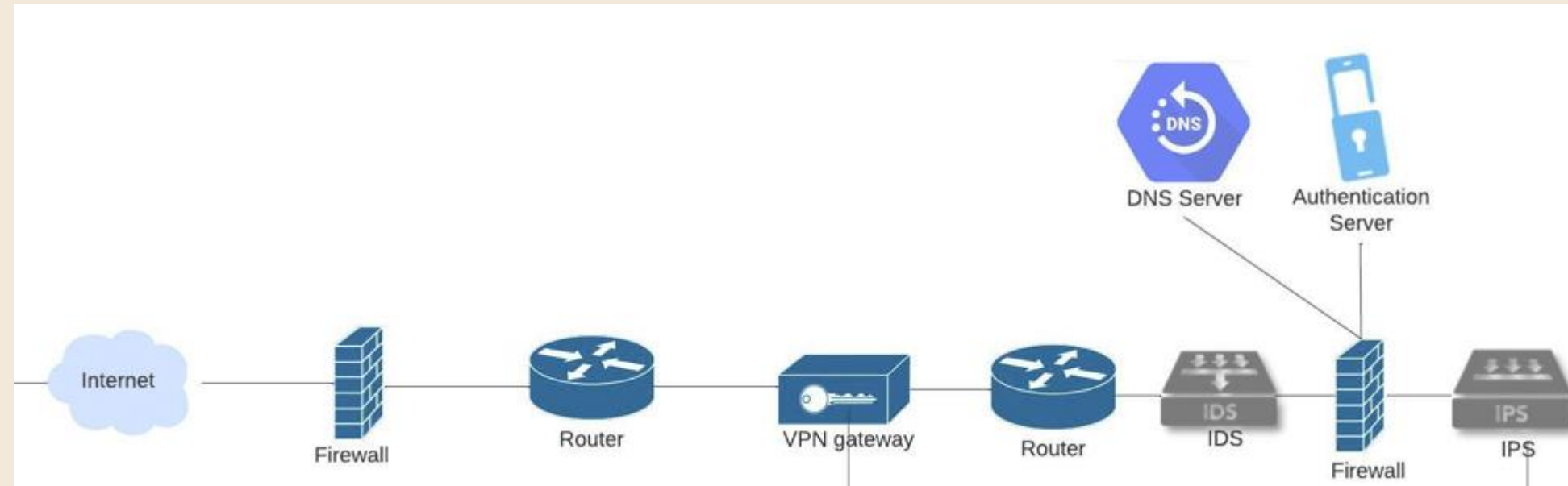
VPN gateway

A bridge connects private networks to public networks. It creates and protects a VPN connection between the transmitter and receiver of data.

Router

The router transmit packets to the administration network and DMZ. Ensures efficient and secure data flow across the network that only allowed traffic reaches specific internal destinations such as the outward-facing servers or the VPN gateway enhance security.

Before Access to Administration Network



Firewall (Internal)

Provide additional filtering within the administration network

Intrusion Prevention System (IPS)

IPS searches for traffic patterns or attack characteristics and generates alerts and prevents the attacks when identified.

DNS Server

The DNS server converts these names into IP addresses, allowing computers to find one another and connect via the network.

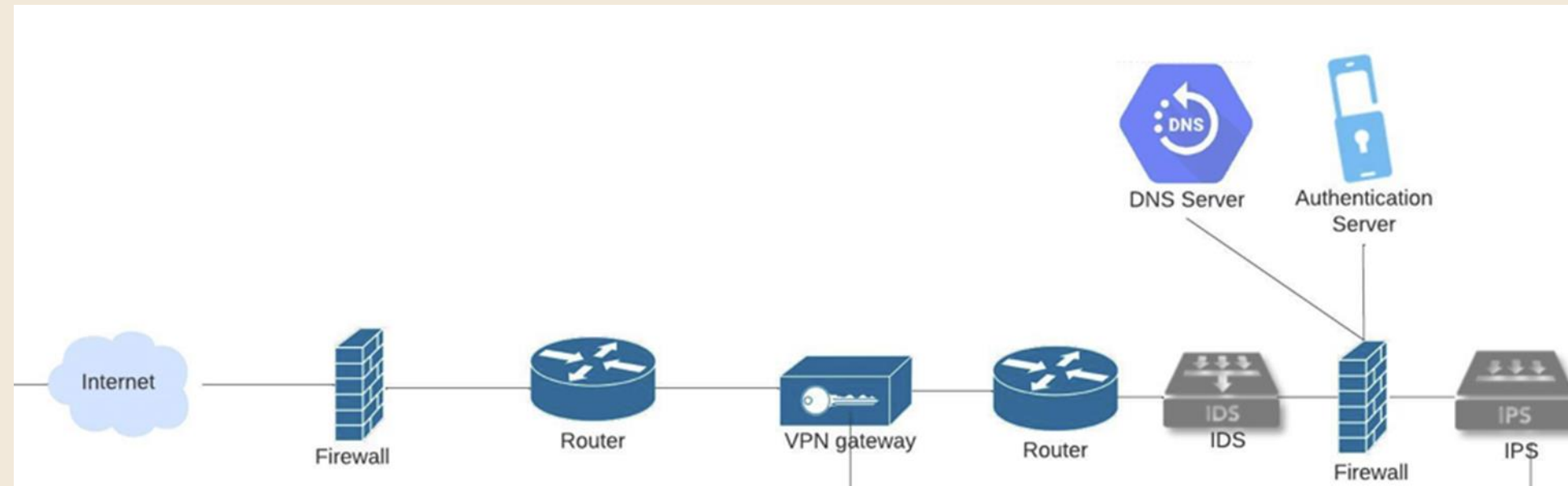
Authentication Server

The authentication server verifies the identities of users and devices attempting to connect to the network ensuring that only authorised individuals and systems gain access. It serves as a gatekeeper, granting access only to those who have authorisation.

Intrusion Detection System (IDS)

Monitors network traffic and searches for malicious activities, send alerts to security teams when it detect any security risk and threats.

Before Access to Administration Network



External Firewall

First layer of security between internet and internal network. The external firewall serves as to filter incoming and outgoing packets to prevent unauthorized access to the company's network to the DNS server and authentication server.

The router in the middle transmits packets to the internal network and DMZ.

Router

A second router located after the VPN gateway to forward packets to the administration network.

VPN Gateway

Employee can connect to VPN gateway to securely access internal network while exposing to production which allows employee to work flexibly.

VPN gateway encrypts data traffic which provides a secure connection that prevents unauthorized access.

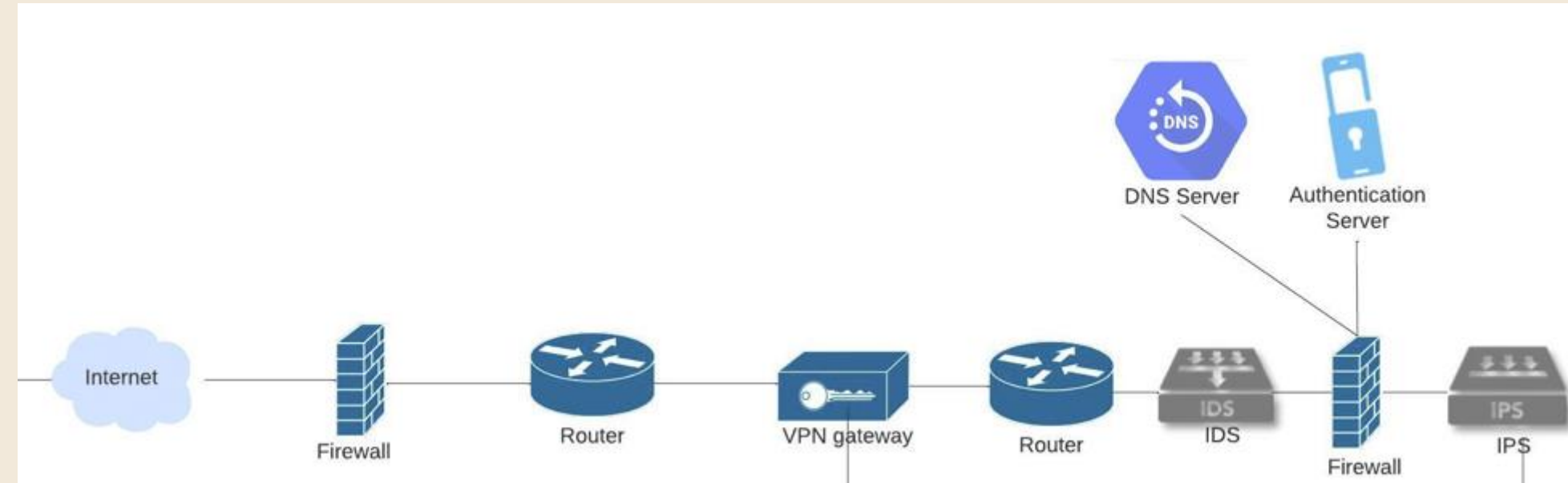
Router

A second router is located after the VPN gateway to forward traffic to the administration network. This router helps isolate VPN traffic and ensures that only properly authenticated traffic flows into the administration network.

IDS

The IDS provides early detection of potential threats that the firewall had missed. This is crucial to avoid downtime or production disruptions. When the attacker bypasses the firewall, IDS will alert security teams. It also can reduce false alarms as the IDS only analyzes packets that pass through the firewalls.

Before Access to Administration Network



Firewall

An internal firewall controls access allowing for stricter security within the network. For instance, it can block access from the Administration network to the Production network which is necessary to prevent malicious activity impacting production systems. It also helps to ensure each department only accesses the resources necessary for their work.

DNS Server

In this network, the DNS server is placed inside after the second firewall. This placement keeps it protected from outside threats and makes it easier for devices within the company to connect to each other using names instead of numbers.

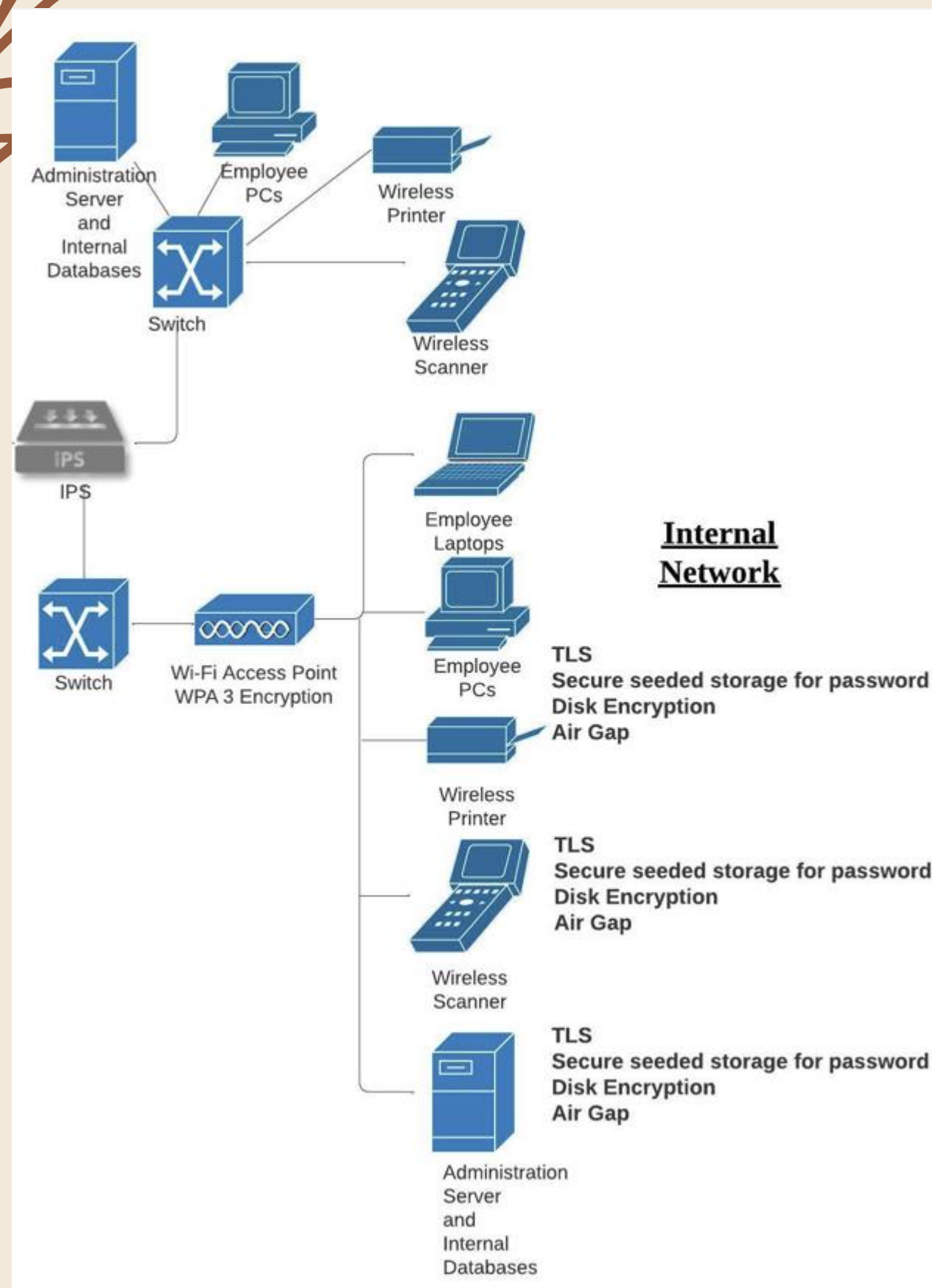
Authentication Server

This server is located within the secure internal network. When someone try access important systems, like the production area. They have to go through this server to confirm their identity first.

IPS

IPS is placed after Firewall because IPS can immediately block any malicious activity before it causes damage. For instance, the IPS can take action to block this threats. It placed after the internal firewall ensures that only filtered, potentially malicious traffic that passes the firewall gets blocked, adding an extra layer of security.

Administration Network



Router and Switch

The router and switch ensures efficient and secure internal data transfer between network and connected devices.

Wi-Fi Access Point

By placing it after the firewall and IPS to ensure that wireless traffic is monitored and protected which to prevent unauthorized devices or users connect the network.

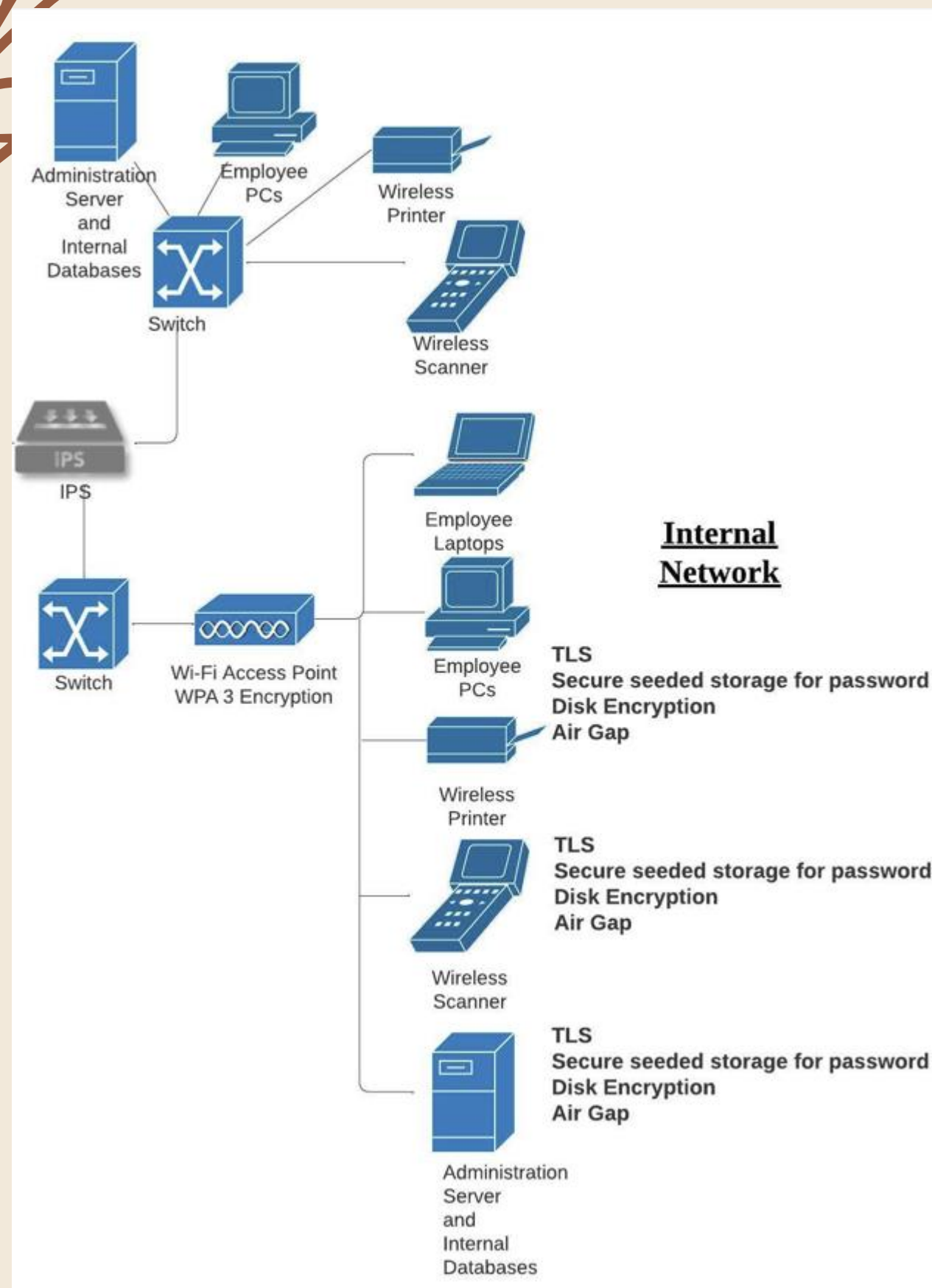
Administration Server and Internal Databases

The employee must validate their identity using the authentication server, which will return a ticket granting access to the customer database server. Each ticket has a different level of permission to the customer database server based on the employee's role.

Employee PCs and printer and scanner

The computers, printers and scanners for confidential departments are kept separate. Confidential departments manage sensitive information which should be restricted to prevent access by unauthorized teams. This separation helps protect the data from potential leaks and reduces the chance of accidental sharing.

Administration Network



Disk Encryption

Used on storage drives in the production machine and PCs to ensure that any data saved on this devices is protected securely. If device or hard drive is stolen, misplaced or accessed without permission, the encrypted data still save unauthorised access. Example BitLock, LUCKS,etc

TLS

TLS encrypts data transmitted over a network ensuring that any information exchanged between employee PCs, the administration server and internal databases. It also detect when someone modifying the data while transmit it. Thus, it help ensure both parties receive the correct data.

Secure Seeded Storage For Password

Password must be securely kept whenever user log in to system to protect from unauthorised access such as when connecting to VPN Client. Using secure seeded storage such as salted hashing techniques the value ae encrypted by the seed(e.g. bcrypt, PBKDF2). The seed used to encrypt and decrypt passwords.

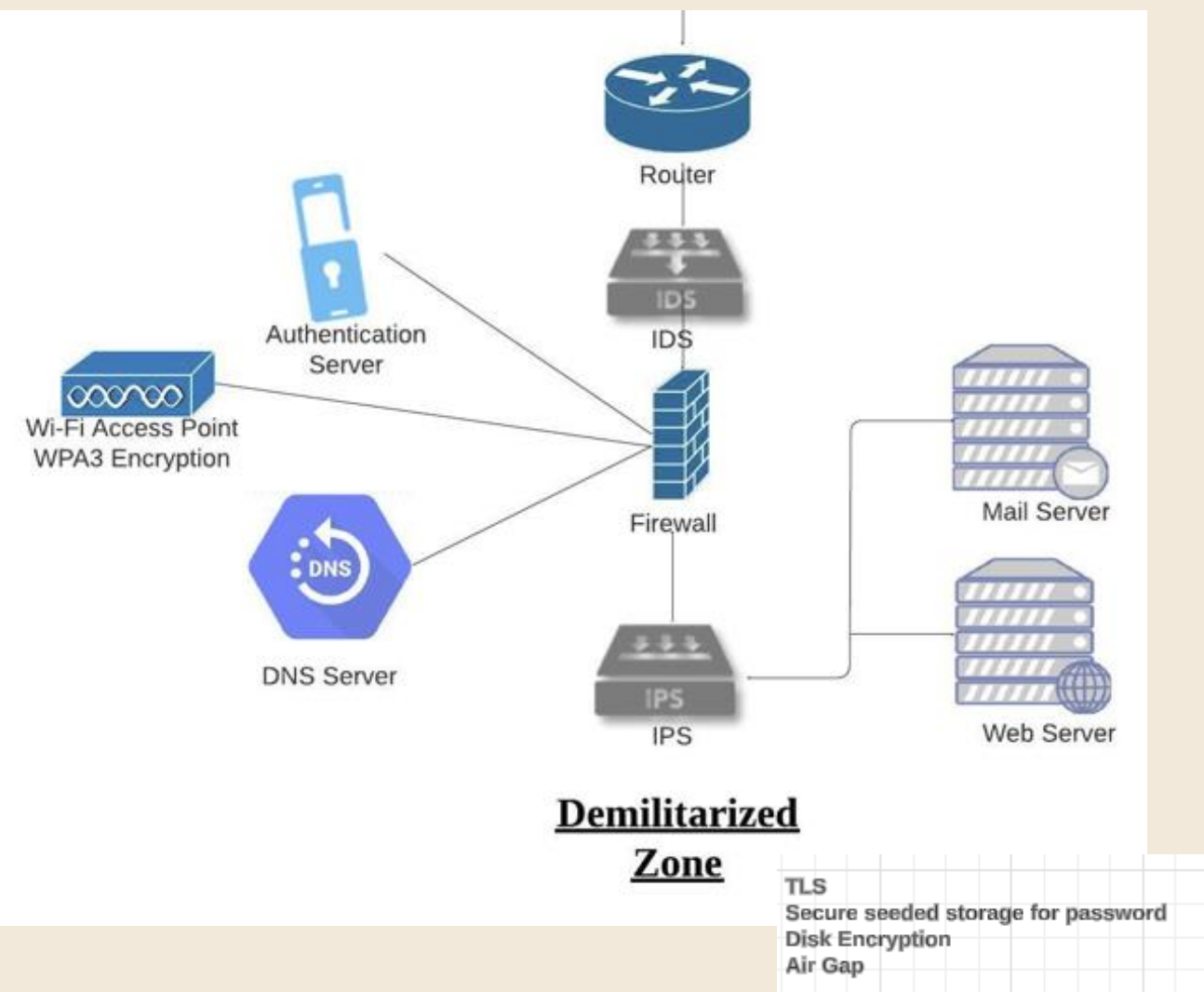
Air Gap

Air gapping is a security technique that isolates systems from all external connections, hence preventing remote cyber-attacks. To protect sensitive data efficiently such as prevents unauthorised access and data leakage.

WPA3 Encryption

Makes it more difficult for unauthorised devices to intercept or break into the Wi-Fi network.

Outward Facing Server



Web Server

Web content example HTML is stored, processed, and served to clients (browsers) through the HTTP/HTTPS protocols.

WiFi Access Point (WPA3 Encryption)

WPA3 uses 192-bit encryption which enhances the security of the data transmitted over wireless networks. WPA3 improves wireless security by providing stronger encryption, improved authentication, protection for open networks.

DNS Server

Converts domain names (e.g., www.website.com) to IP addresses allowing browsers to find web servers.

Authentication Server

Manages external authentication requests while protecting the local network. It improves security through isolation which allows for centralised user management.

TLS

TLS encrypts data transmitted over a network ensuring that any information exchanged between employee PCs, the administration server and internal databases. It also detect when someone modifying the data while transmit it. Thus, it help ensure both parties receive the correct data.

Outward Facing Server

Authentication Server

Authentication server through the firewall which allow authorized devices and users have permission access to network.

DNS Server

A firewall connection to authentication server ensures that DNS traffic is filtered, protecting the DNS server from malicious activities.

IPS

Deals only traffic that pass through firewall , use deep packet inspection to analyze and prevent specific attacks.

Wi-Fi Access point for Employee

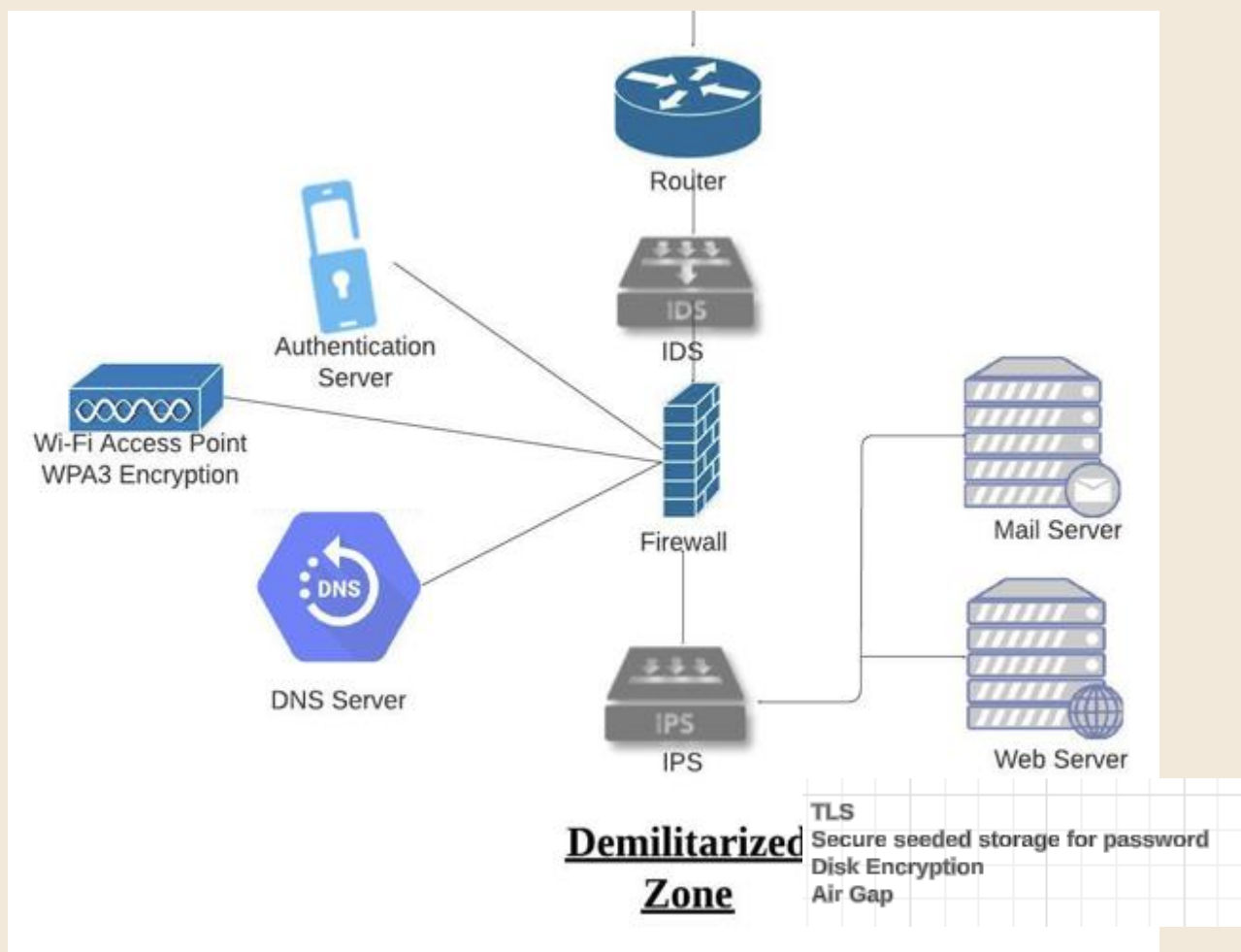
WPA 3 ensures the privacy and integrity of data exchanged across a network. The access point set up in DMZ so that employee may use our Wi-Fi without obtaining access to Administration Network.

Web Server

By inspecting HTTP and HTTPS traffic, the IPS detects and blocks suspicious patterns that trigger attacks. This minimize the risk of data breach.

Mail Server

The IPS inspects email traffic (SMTP) for threats such as phishing attack, protect sensitive information and preventing malicious emails from entering the network.



Outward Facing Server

Router

Monitors and controls packets from the network traffic.

IDS

An Intrusion Detection System (IDS) is a passive security monitoring system that continuously monitors network traffic and system activities to detect suspicious behaviour or violations of security policies. It acts as a surveillance system between the router and the firewall. It logs potentially malicious activities but does not directly prevent them.

Firewall

It is a barrier between DMZ and production network to protect unauthorised access. Port numbers allowed to be accessed: TCP 443, TCP 80, TCP 25, TCP 465, TCP 587, TCP 993, TCP 995, TCP 636, UDP 53, UDP 1194 (Administration server, Web Server, Mail Server, Authentication Server, Mail Client)

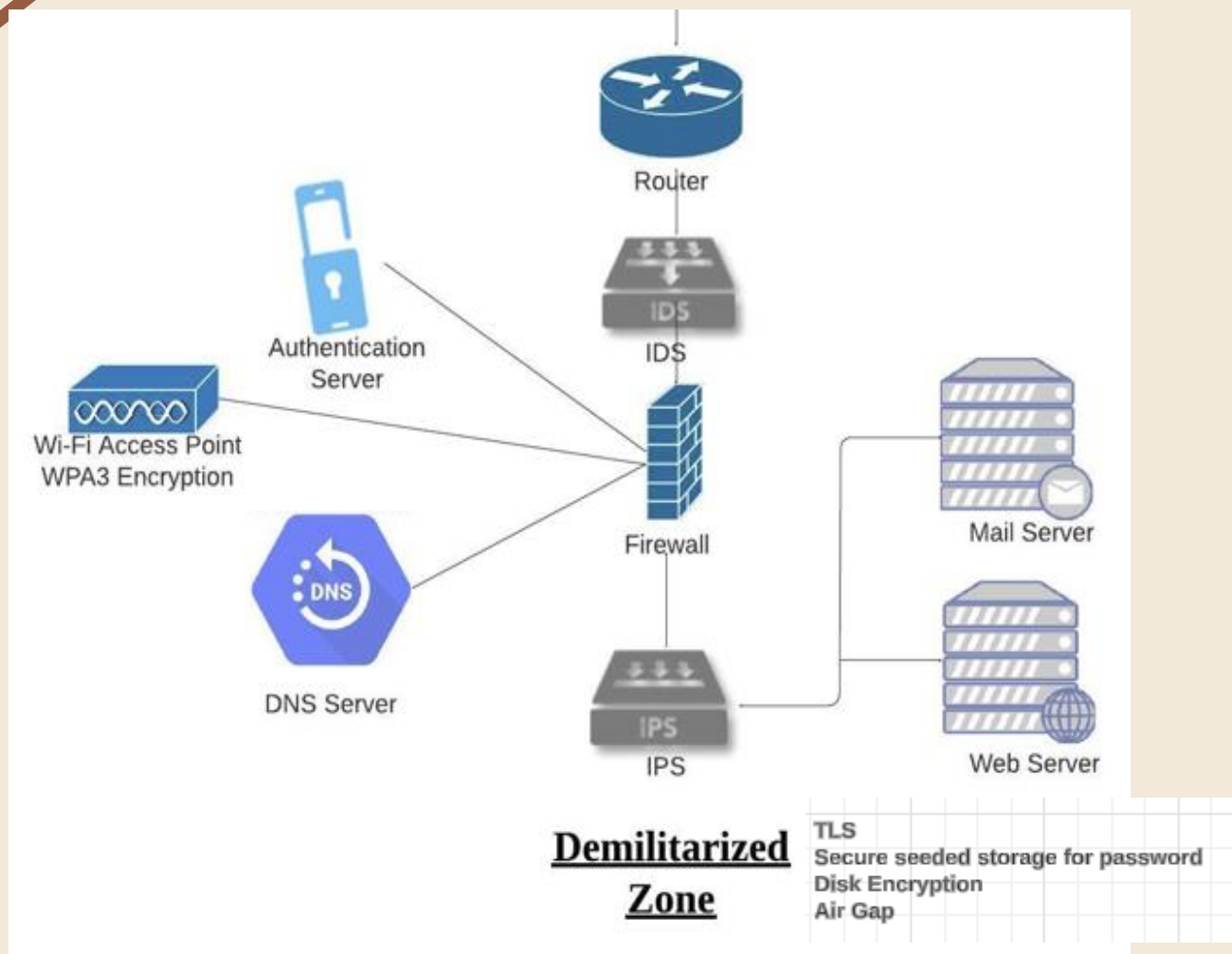
Ensure that only authorized packets can go through to protect the DMZ.

IPS

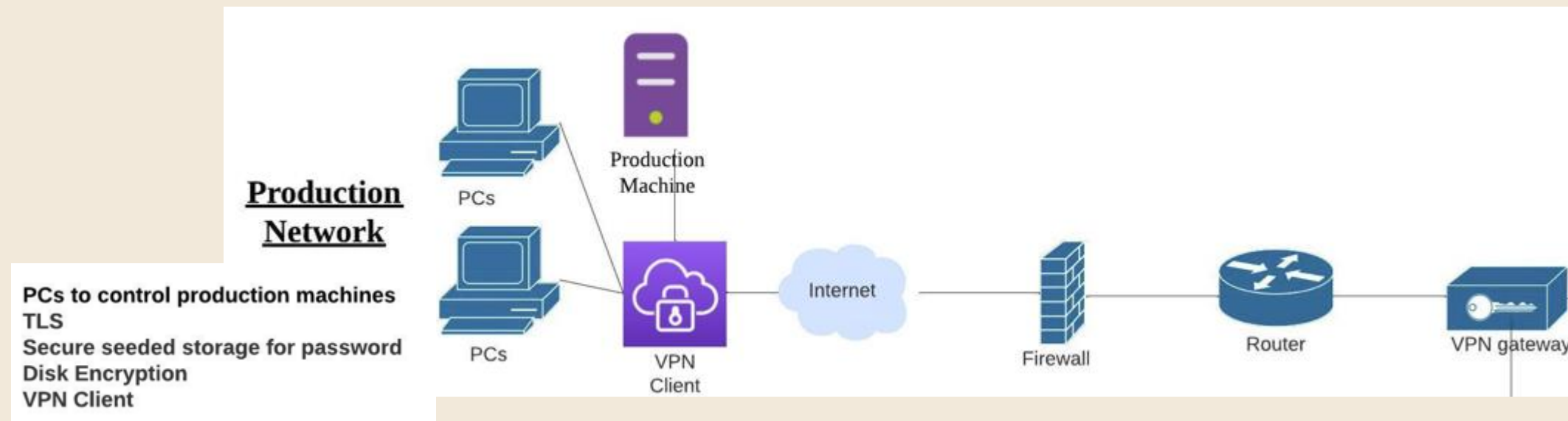
IPS active system monitor and analyse traffic such as filter and block or isolate malicious activity automatically which stop the attack from spreading in real time. It works closely with firewall to reinforce security.

Mail Server

Mail servers enable email communication via a set of protocols and packet exchanges. Emails are sent using SMTP.



Production Network



Disk Encryption

Used on storage drives in the production machine and PCs to ensure that any data saved on this devices is protected securely. If device or hard drive is stolen, misplaced or accessed without permission, the encrypted data still save unauthorised access. Example BitLock, LUCKS,etc

Secure seeded storage of password

Password must be securely kept whenever user log in to system to protect from unauthorised access such as when connecting to VPN Client. Using secure seeded storage such as salted hashing techniques the value ae encrypted by the seed(e.g. bcrypt, PBKDF2). The seed used to encrypt and decrypt passwords.

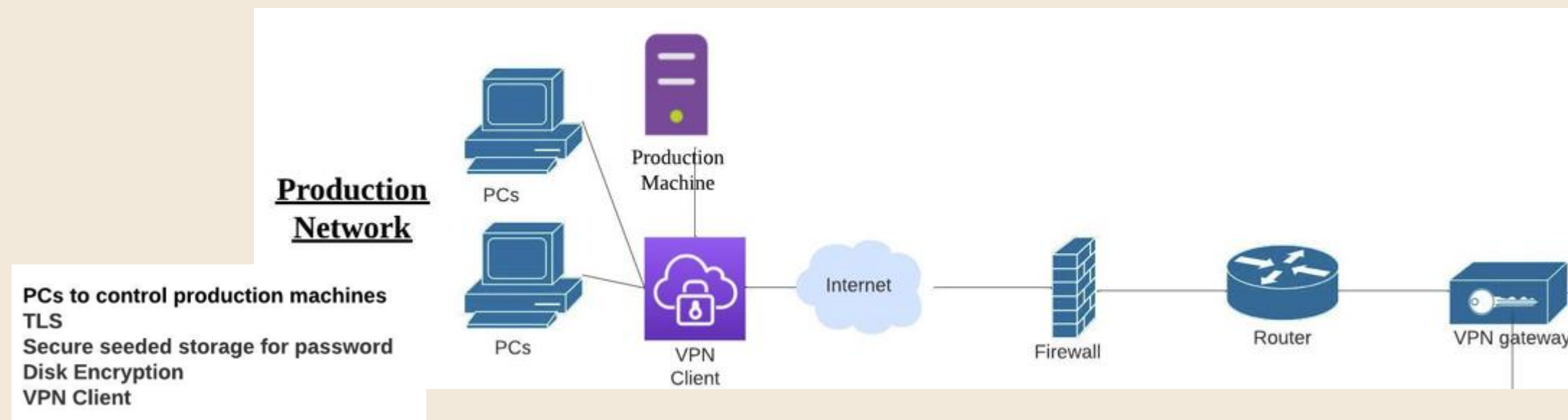
TLS

TLS would be locate between VPN Client and administration network, secure the connection between client and server by using encryption algorithms. It also can identify someone altering the data while transferring. Thus, it also helps to ensure that client and server to receive accurate data.

VPN Client

The VPN Client securely connects users to the VPN gateway, offering private internet access by encrypting all data passed between the user's device and the VPN server. This encryption keeps data secure and protected against unauthorised access.

Production Network



PCs need a multi-layer security to control production network

VPN Client– To securely access internal company networks, employees need install a VPN client on their PCs. This creates an encrypted connection, guaranteeing that no unauthorised users can steal the company information when employees work publicly, outside of the company or insecure networks.

Disc encryption (e.g., BitLocker, LUKS) is installed to encrypt the data in the computer. This ensures that even if a computer is lost or stolen, the data is safe and cannot be accessed without the necessary decryption credentials.

Secure seeded storage of passwords–Each PC should have strong, unique passwords that are securely hashed with a random seed. This prevents attackers from breaking passwords, even if they have access to the hashed values and salt.

TLS–Applied to PCs to encrypt all network communications. This ensures the integrity and secrecy of data exchanged between the PC and company systems



Reference

Barracuda. (2024). *VPN Client*. Barracuda. <https://www.barracuda.com/support/glossary/vpn-client>

Checkpoint. (n.d.). *Intrusion Detection System (IDS) Vs Intrusion Prevention System (IPS)*. Check Point Software. <https://www.checkpoint.com/cyber-hub/network-security/what-is-an-intrusion-detection-system-ids/ids-vs-ips/>

External Firewall - an overview | ScienceDirect Topics. (n.d.). Wwww.sciencedirect.com. <https://www.sciencedirect.com/topics/computer-science/external-firewall>

Fortinet. (2022). *What is an IPS (Intrusion Prevention System)?* Fortinet. <https://www.fortinet.com/resources/cyberglossary/what-is-an-ips>

Fortinet. (2023). *What is an Intrusion Detection System (IDS)?* Fortinet. <https://www.fortinet.com/resources/cyberglossary/intrusion-detection-system>

IPS vs IDS: What's the Difference and Why It Matters | Tech Impact. (2023, October 26). Techimpact.org. <https://techimpact.org/news/ips-vs-ids-whats-difference-and-why-it-matters>

What Is a VPN Gateway? (n.d.). Palo Alto Networks. <https://www.paloaltonetworks.com/cyberpedia/what-is-a-vpn-gateway>

What is an Air Gap? Benefits and Best Practices. (2024, September 10). SentinelOne. <https://www.sentinelone.com/cybersecurity-101/cybersecurity/what-is-an-air-gap/>



THANK YOU